Product Requirements Document (PRD)

MedInfo Assistant - Medical Research & Report Analysis Multi-Agent GenAI Platform

Generated 2026-10-15 from 01-PRD.md - information only, not medical advice.

Contents

0. Document control
1. Executive summary
2. Problem statement
3. Vision, goals and non-goals
4. Success metrics and KPIs
5. Users and personas
6. Scope
7. User journeys
8. Epics and user stories (with acceptance criteria)
9. Functional requirements
10. Non-functional requirements
11. Medical safety requirements and clinical governance
12. Data requirements
13. Privacy, security and compliance considerations
14. UX and UI requirements
15. Integrations and dependencies
16. Release plan
17. Risks and mitigations
18. Assumptions, constraints and open questions
19. Glossary
20. End-to-end solution overview
21. Operational and support requirements
22. Requirements traceability matrix
23. Launch readiness checklist (production v1)
24. Approvals

0. Document control

Field	Value
Document	Product Requirements Document (PRD) - source of truth for requirements
Product	MedInfo Assistant
Version	2.0 (production-grade rewrite of v1.0 summary)
Status	**Draft for approval**
Date	2026-10-14
Owner	Product Owner (project author)
Required reviewers	Product, Clinical Safety Officer, Information Security, Data Protection Officer, Engineering Lead
Related documents	HLD, Architecture, LLD, API, Security & Privacy, Test Strategy, ADRs

Change log

Version	Date	Change
1.0	2026-10-14	Initial requirement summary
2.0	2026-10-14	Full PRD: personas, epics, user stories with acceptance criteria, NFR targets, governance, compliance considerations, release plan, risks, sign-off

Status legend used in this document

Label	Meaning
Implemented	Built and covered by automated offline tests
Verified live	Also exercised against real services (recorded transcript, 2026-10-14)
Planned	Specified; not built, or built but not yet verified where noted
Target	A goal to be measured; not a claim that it has been achieved

> **Honesty rule.** This product makes no claim of clinical validation, diagnostic accuracy or regulatory approval. All evaluation figures are offline evaluations on synthetic test sets unless a documented clinical evaluation states otherwise.

1. Executive summary

MedInfo Assistant is a web application that answers **medical information and research questions only from trusted, cited sources**, analyses user-provided documents (for example case notes, papers, lab tables) as untrusted evidence, and produces downloadable **evidence reports**. It is built as a pipeline of specialised AI agents - triage, scope classification, retrieval and re-ranking, grounded answering, verification and, for clinicians, a research agent - wrapped in a deterministic safety layer.

The product's defining property is **safe failure**: when it cannot verify an answer against a source it refuses or says the topic is not covered; when a question suggests an emergency it leads with emergency advice; it never diagnoses, prescribes or changes doses.

The current release is a **production-ready architecture running locally with synthetic data**: the core path is verified against the live database and model provider; the delivery stack (containers, Kubernetes, Terraform, CI/CD) is written and statically validated; deployment to AWS is planned.

2. Problem statement

2.1 Context

Patients, carers and clinicians increasingly turn to AI chat tools for medical information. Those tools are fluent but are not designed for medical risk:

1. **Ungrounded answers.** General chatbots answer from model memory, rarely cite sources and cannot show which guideline, version or page a statement comes from.
2. **Confident errors.** Fluent wording hides hallucinated numbers, drug names and doses.
3. **Scope creep into clinical decisions.** Users ask "Do I have…?" and "Can I double my dose?"; general tools often answer, effectively diagnosing or prescribing.
4. **Missed emergencies.** Urgent symptoms (chest pain, stroke signs, self-harm) are answered like any other question instead of being escalated first.
5. **Document analysis risk.** Uploaded reports and web pages can contain hidden instructions (prompt injection) and personal health information (PHI).
6. **Evidence decay.** Guidelines are revised; versions conflict; users cannot tell which applies.
7. **Research friction.** Clinicians and researchers spend time cross-checking guidelines, labels, tables and literature, then re-typing findings into reports.

2.2 Problem statement

> People who need medical information, and clinicians who research it, lack a tool that **answers only from trusted, traceable evidence**, **escalates emergencies first**, **refuses unsafe clinical decisions**, **protects personal health data**, and **turns analysis into a verifiable report**.

2.3 Why now

Retrieval-augmented generation, structured output from LLMs, and managed vector databases make a grounded, auditable assistant feasible at low cost - provided safety is designed into the architecture rather than added as a prompt.

---

3. Vision, goals and non-goals

3.1 Vision

The safest way to understand medical evidence: every statement traceable, every risk escalated, every limit stated.

3.2 Goals

ID	Goal
G1	Answer only from trusted or user-provided evidence, with a citation for every statement
G2	Escalate urgent symptoms before any other content
G3	Never diagnose, prescribe, choose a medicine or change a dose
G4	Protect PHI: minimise, redact, encrypt, audit, delete on request
G5	Turn analysis into a downloadable, cited evidence report
G6	Make safety measurable: release-blocking tests and continuous monitoring
G7	Be operable in production: secure containers, observability, failure handling, automated delivery

3.3 Non-goals (hard boundaries)

- Diagnosis, triage decisions on behalf of a clinician, treatment plans, prescribing, dose changes.
- Replacing professional medical advice or emergency services.
- Claims of clinical accuracy, validation or regulatory clearance.
- Processing real patient data before governance approval (section 12).

---

4. Success metrics and KPIs

All values below are **targets**. "Current" reports what has actually been measured.

#	Metric	Target	Current (2026-10-14)
K1	Safety-suite pass rate per set (emergency, dosing, diagnosis, injection, PHI, out-of-corpus)	100% (release gate)	100% offline (240 tests, incl. adversarial fake model); live run not yet performed
K2	PHI leaks in prompts, logs, memory, embeddings, outputs	0	0 in offline probes
K3	Evidence hit rate @5 on golden set	>= 90%	Offline guard passes (fake embeddings); live not yet measured
K4	Citation accuracy (LLM judge)	>= 95%	Not yet measured
K5	Faithfulness (claims supported by context)	>= 95%	Not yet measured
K6	Clinician review: answers rated "unsafe"	0	No reviews yet
K7	p95 latency, `/api/chat`	<= 15 s	Not yet measured under load
K8	Availability (monthly)	>= 99.5%	Not deployed
K9	Emergency notice shown when provider is down	100%	Implemented + tested offline
K10	Refusal rate (monitored, not gated)	Tracked; alert on +-20 pp shift	Alert rule written

5. Users and personas

Persona	Description	Needs	Role
Priya - informed patient/carer	Reads about a family member's condition; not medically trained	Plain language, trustworthy sources, clear "see a doctor" boundaries, emergency direction	user
Dr Mehta - clinician	Checks guidelines and labels between consultations; wants literature context	Fast cited answers, version awareness, research mode, exportable evidence	clinician
Sam - content admin	Maintains the trusted corpus	Upload with provenance, see what is indexed, remove outdated documents	admin
Clinical Safety Officer	Owns clinical risk	Review sampled answers, red-flag rules sign-off, safety metrics	clinician/admin
Ops engineer	Runs the service	Health probes, dashboards, alerts, safe deploys, audit trail	infrastructure access

Accessibility: users may be stressed, on mobile, or using assistive technology (section 10).

6. Scope

Capability	MVP (current)	v1 (production launch)	Later
Grounded Q&A with citations	Verified live	Real licensed corpus	Multilingual
Emergency triage	Verified live	Clinician-approved rules, region numbers	Locale-specific crisis services
Diagnosis / dosing refusal	Verified live (strict refusal)	Improved quote-only answers	-
Document upload and analysis	Implemented	+ virus scanning	EHR import
Research mode (web)	Implemented (fakes)	Verified live with Tavily	More sources
Evidence report	Implemented (Markdown)	PDF export	Shareable links
Conversation history	Implemented	Retention job scheduled	-
Clinician review	Implemented	Clinical safety case process	-
Evaluation + MLflow	Implemented	Live runs per release	Real-world eval set
Observability	Implemented (files)	Running dashboards + paging	SLO burn alerts
Deployment	Local; IaC validated	AWS EKS (approval needed)	Multi-region

7. User journeys

7.1 Patient/carer - "understand a condition"

1. Signs in (email + password).
2. Asks "What is hypertension and how is it defined?".
3. Sees live progress: checking safety -> searching sources -> writing -> verifying.
4. Reads a short answer where every sentence has a citation chip; opens "Sources and limitations" to see publisher, page, version and date; sees a note that two guideline versions differ.
5. Asks a follow-up in the same conversation; downloads the evidence report.

7.2 Patient/carer - "urgent symptoms"

1. Types "I have crushing chest pain spreading to my jaw".
2. A red banner pinned at the top says to call the emergency number now - before any other content.
3. Any general information shown below is cited; no reassurance replaces the emergency advice.

7.3 Clinician - "research a question"

1. Enables research mode; asks a literature/guideline question.
2. The research agent searches the corpus and allow-listed medical sites; web results are labelled and cited by URL; the answer passes the same verification.
3. Exports the evidence report into their notes.

7.4 User - "analyse my document"

1. Uploads a case note or paper (PDF, Word, image...). PHI is redacted; hidden instructions are removed.
2. Asks about it; citations show the document as "user-provided". Nobody else can see it.
3. Deletes the document and their history when done.

7.5 Admin - "curate the corpus"

1. Drags a guideline into Documents, enters provenance (publisher must be on the allow-list).
2. Sees chunks indexed; re-uploading an unchanged file re-embeds nothing; deletes superseded files.

7.6 Clinical Safety Officer - "review"

1. Opens the review queue of sampled (redacted) answers; records verdicts with notes.
2. Exports verdicts; monitors safety metrics and alerts.

---

8. Epics and user stories (with acceptance criteria)

Epic E1 - Authentication and roles

US-1.1 As a user I want to sign in with email and password so that my data stays mine.

- *Given* valid credentials, *when* I sign in, *then* I reach the chat and my role is shown.
- *Given* a token signed with HS256 or "none", an expired token (beyond 30 s skew), or a wrong audience, *then* every API call returns 401.
- Status: **Implemented; Verified live** (3 accounts: user, clinician, admin).

US-1.2 As an operator I want roles from a trusted source so that users cannot grant themselves access.

- Roles are read only from `app_metadata`; the top-level `role` claim is ignored.
- A user receives 403 on admin and review endpoints; a clinician receives 403 on admin endpoints.
- Status: **Implemented; Verified live**.

Epic E2 - Ask and answer

US-2.1 As a user I want answers only from trusted sources so that I can rely on them.

- Every factual sentence ends with a citation to a provided passage; otherwise the answer is replaced by a refusal explaining it could not be verified.
- Numbers and known drug names in the answer must appear in the cited passages.
- If no relevant source exists, the reply is "not covered by the available sources" and the answer model is not called.
- Status: **Implemented; Verified live**.

US-2.2 As a user I want to see where each statement comes from.

- Citation chips open source cards with title, publisher, section/page/slide/sheet, version, date and badges (user-provided, web, older version, may be outdated).
- Status: **Implemented**.

US-2.3 As a user I want to know the limits of an answer.

- Every answer ends with an evidence basis, a limitations line and the disclaimer, added in code.
- Version conflicts and sources older than 5 years are stated.
- Status: **Implemented; Verified live**.

US-2.4 As a user I want follow-up questions to keep context.

- Follow-ups are rewritten into standalone search queries using the conversation; the answer still cites only retrieved passages.
- Status: **Implemented**.

US-2.5 As a user I want to see how an answer was produced so that I can judge how much to trust it.

- Every answer (including emergency, refusal, redirect and not-covered replies) has a collapsible "How this answer was produced" panel listing, in order, each agent that ran (input guardrails, triage, scope, answer cache, query rewriter, retriever + re-ranker or research agent, answer agent, output guardrails, verifier, result) with its outcome, a short detail, a status (done / attention / stopped here / skipped) and its duration in ms.
- The panel shows where an emergency, block or failed check stopped the pipeline.
- The trace holds decisions and counts only: never question text, answer text, passage text or upload filenames; it is rendered as text only.
- Status: **Implemented + tested offline** (8 backend tests incl. a no-PHI test; 2 browser tests).

Epic E3 - Emergency handling

US-3.1 As a user describing urgent symptoms I want emergency advice first.

- Rules (12 categories) or the LLM classifier triggering shows the emergency notice with the configured number at the top, pinned, before any content; the model never writes or edits this text.
- If the model provider is down, the notice is still shown.
- Self-harm: crisis-line resources are shown and no generated content follows.
- Status: **Implemented; Verified live** (chest pain).

Epic E4 - Clinical boundaries

US-4.1 As a user asking about doses I must not receive dosing advice.

- The reply refuses to recommend, start, stop or change a medicine; any dose shown is a verbatim, cited quote from a label or guideline; "Talk to your doctor or pharmacist before changing any medicine" is shown.
- Status: **Implemented; Verified live** (strict refusal variant).

US-4.2 As a user asking "Do I have…?" I must not be diagnosed.

- Diagnostic phrasing aimed at the user is removed and a referral is shown with general information.
- Status: **Implemented**.

US-4.3 As a user I must not get help with harmful requests.

- Requests for lethal doses, drug misuse or harmful synthesis are refused with support resources.
- Status: **Implemented**.

Epic E5 - Documents

US-5.1 As a user I want to upload my own document and ask about it privately.

- Supported: PDF (per page, OCR for scans), DOCX, PPTX, XLSX, CSV/TSV, text, PNG/JPG; max 10 MB.

- PHI and secrets are redacted before embedding; instruction-like lines are neutralised and flagged.
- Only the owner can retrieve, list or delete it (others receive 404).
- Status: **Implemented**.

US-5.2 As an admin I want to ingest trusted sources with provenance.

- Only allow-listed publishers are accepted; every chunk carries source, publisher, date, version, evidence level, jurisdiction and licence.
- Unchanged files re-embed nothing; changed chunks only are re-embedded; stale chunks are deleted.
- Status: **Implemented; Verified live** (11 synthetic documents, 25 chunks, re-ingest skipped all).

Epic E6 - Research mode

US-6.1 As a clinician I want literature and guideline context beyond the corpus.

- Research mode is available to clinician and admin roles only.
- Web results come only from allow-listed medical domains (checked locally), are labelled untrusted, cited by URL, and pass the same verification as other answers.
- Status: **Implemented (fakes); Planned: live verification**.

Epic E7 - Evidence reports

US-7.1 As a user I want to download an evidence report of my conversation.

- The Markdown report lists each question, the answer, sources (publisher, location, date, URL), limitations and the disclaimer; it contains only redacted text; only the owner can download it.
- Status: **Implemented**. Planned: PDF format.

Epic E8 - History and privacy

US-8.1 As a user I want to view and delete my history.

- I can list, open and delete one or all of my conversations; others cannot see them.
- Conversations older than the retention period (default 30 days) are purged.
- Status: **Implemented**; Planned: scheduled purge job.

Epic E9 - Clinician review

US-9.1 As a Clinical Safety Officer I want to review sampled answers.

- A configurable share of answers (redacted) enters a queue; verdicts: safe and correct, minor issue, incorrect, unsafe; admins export verdicts as JSON or CSV.
- Status: **Implemented**.

Epic E10 - Evaluation and quality

US-10.1 As the product owner I want release decisions based on measured safety.

- CI fails if any safety-suite set falls below 100%.
- Evaluation runs log parameters, metrics and per-question artefacts to MLflow and are shown to admins, labelled "offline evaluation on a synthetic test set".
- Status: **Implemented**; Planned: first live MLflow run.

Epic E11 - Operations

US-11.1 As an ops engineer I want to detect problems early.

- Metrics: p50/p95/p99 latency per route, model and retrieval latency, triage events, refusals by reason, guardrail events, hallucination flags, cache hits, circuit state, rate limits.
- Alerts: triage spikes, refusal-rate shifts, safety-check failures, open circuits, high p95 latency.
- Status: **Implemented (as code/config)**; Planned: running in an environment.

---

9. Functional requirements

Priority: **M** = must, **S** = should, **C** = could (MoSCoW).

ID	Requirement	Pri	Status
FR-01	Urgent-symptom triage first on every question (rules + temperature-0 LLM); either fires	M	Verified live
FR-02	Emergency notice built in code, shown first, survives provider outage; crisis resources for self-harm	M	Implemented
FR-03	Scope classification into 7 classes; stricter of rules/LLM wins; fixed response per class	M	Verified live
FR-04	Grounded generation (answers 0.1-0.3 temperature) from numbered passages only	M	Verified live
FR-05	Post-answer checks: citations, numbers, drug names, dosing quotes, diagnosis removal	M	Implemented
FR-06	Faithfulness judge (temperature 0) on high-risk topics; fail closed	M	Implemented
FR-07	"Not covered" without calling the model when no passages are retrieved	M	Verified live
FR-08	Fixed wording: evidence basis, limitations, medicine warning, disclaimer	M	Implemented
FR-09	Input/document/output guardrails from a policy file; safety rules not weakenable	M	Implemented
FR-10	Local PHI/PII and secret redaction before any third-party call, cache, memory or log	M	Implemented
FR-11	Loaders for PDF/DOCX/PPTX/XLSX/CSV/TSV/text/images; OCR for scans; locations kept	M	Verified live (incl. OCR)
FR-12	Chunking: recursive (15%), semantic, parent-child (10%), table-aware	M	Implemented
FR-13	Incremental upsert by content hash; CRLF normalisation; delete document	M	Verified live
FR-14	Trusted-publisher allow-list; provenance on every chunk	M	Verified live
FR-15	Private, untrusted user uploads labelled "user-provided"	M	Implemented
FR-16	Hybrid retrieval (pgvector + BM25-style FTS), RRF, LLM re-ranker	M	Verified live
FR-17	Metadata filters ("Search in"); newest guideline version preferred; conflicts stated	S	Implemented

ID	Requirement	Pri	Status
FR-18	Research agent (ReAct, max 3 tool calls) with allow-listed web search	S	Implemented (fakes)
FR-19	Short-term (Redis) and long-term (Postgres, encrypted) memory; follow-up rewriting	S	Implemented
FR-20	Answer cache (clean answers only, invalidated on document change); safe LLM prompt cache	S	Implemented
FR-21	Fallback model chain with circuit breakers; retries with backoff; error mapping 429/502/503	M	Implemented
FR-22	Per-user rate limits with Retry-After	M	Implemented
FR-23	Streamed progress phases (SSE)	S	Implemented
FR-24	Evidence report download	S	Implemented
FR-25	Clinician review queue and export	S	Implemented
FR-26	Evaluation runner with MLflow; admin evaluation view	S	Implemented; verified live (live evaluation 2026-10-15 (offline evaluation on a synthetic test set): safety suite 100% in every set; correctness 0.857, citation accuracy 0.929, faithfulness 1.0; two dosing/interaction questions over-refused)
FR-27	Conversation deletion and retention purge	M	Implemented (job scheduling planned)
FR-28	Audit log per request and per action without PHI	M	Implemented
FR-29	Agent trace per answer ("How this answer was produced"): agent, outcome, detail, status, ms; decisions and counts only, no user text	S	Implemented
FR-30	LLM gateway: every model call routed by task (fast/quality chain), per-task min/max output tokens and input budget (answer passages trimmed lowest-rank first), token usage metrics, query-embedding cache; over budget never weakens safety	S	Implemented (not yet measured live)

10. Non-functional requirements

Category	Requirement	Target	Status
Performance	p95 `/api/chat` latency	<= 15 s (multi-call pipeline)	Not measured under load
Performance	Time to first progress phase	<= 1 s	Implemented (SSE); not measured
Availability	Monthly availability	>= 99.5%	Planned (needs deployment)
Scalability	Horizontal scaling of stateless pods	2-8 backend replicas (HPA)	Configured
Resilience	Provider failure degrades gracefully	Fallback + circuit breakers; emergency always shown	Implemented
Security	Authentication	Supabase JWT, ES256/RS256 via JWKS, 30 s skew leeway	Verified live
Security	Authorisation	RBAC on every route; owner checks	Verified live
Security	Web security	Strict CSP, no inline script, text-only rendering, no external assets	Implemented
Security	Supply chain	Pinned dependencies; Trivy gate (fixable HIGH/CRITICAL)	Configured in CI
Security	Runtime	Non-root uid 10001, read-only root FS, no capabilities, default-deny network	Configured
Privacy	Data minimisation	PHI redacted before egress; synthetic data only	Implemented
Privacy	Encryption	TLS in transit; at rest (database, KMS secrets, app-level messages)	Implemented / configured
Privacy	Retention	30-day conversation retention; user deletion	Implemented
Accessibility	WCAG 2.1 AA (target)	Keyboard, focus, labels, contrast, reduced motion, mobile	Implemented; no formal audit yet
Observability	Metrics, dashboards, alerts, audit	As in US-11.1	Implemented as config
Maintainability	Test coverage of safety-critical paths	All safety behaviours tested offline	419 backend + 10 browser tests
Portability	Local, Docker, Kubernetes	Same images	Docker build not yet run locally
Cost	Quota-aware operation	Call estimates before live runs; caching; rate limits	Implemented

11. Medical safety requirements and clinical governance

1. **Clinical safety case** (planned): hazard log, risk assessment and mitigations owned by a named Clinical Safety Officer, reviewed before any real-user release.
2. **Red-flag rules** require clinician sign-off; status recorded in the rules file (currently `draft_pending_clinician_review`).
3. **Release gate:** 100% safety-suite pass; any regression blocks release.
4. **Post-release monitoring:** triage spikes, refusal shifts and safety-check failure alerts; clinician review sampling; incident process for any "unsafe" verdict.
5. **Change control:** any change to triage, scope, guardrails, prompts or templates requires updated safety tests and review.

12. Data requirements

Data	Source	Requirement
Trusted corpus	Allow-listed publishers	Licence confirmed and recorded before ingestion; provenance on every chunk
Current corpus	Synthetic	11 fictional documents (fictional drugs, doses, publisher), regenerated by script
User uploads	Users	Untrusted; PHI-redacted; private; deletable
Conversations	Users	Redacted, encrypted, retained 30 days, deletable
Evaluation data	Golden set + safety suite	Synthetic; verbatim evidence quotes verified by tests
Real patient data	-	**Prohibited** until DPIA, provider DPAs and clinical approval are in place

13. Privacy, security and compliance considerations

The product is designed to support, **not claim**, compliance. Before production use with real data the following must be assessed by qualified people:

Framework (by deployment region)	Consideration
India - Digital Personal Data Protection Act 2023	Consent, purpose limitation, data principal rights (access, erasure), breach notification
EU/UK - GDPR / UK GDPR	Lawful basis for health data (special category), DPIA, processor agreements, data residency
UK - DCB0129 / DCB0160	Clinical risk management for health IT (manufacturer / deployer)
US - HIPAA	Only if handling PHI for covered entities: BAAs with every processor
Medical device regulation (any region)	Intended use is information only; any diagnostic or treatment function would change classification - out of scope

Third parties receiving data: model provider chain (redacted questions and passages), embedding provider (redacted uploads), search provider (redacted research queries), Supabase (database and authentication).

14. UX and UI requirements

- Persistent disclaimer: "Information only, not medical advice. In an emergency call ."
- Emergency banner pinned at the top when triggered; refusal cards explain why and where to get help.
- Every answer shows a "Sources and limitations" panel; user-provided and web sources are visibly labelled.
- Every answer shows a collapsible "How this answer was produced" panel (agent steps, outcomes, timings).
- Progress phases while the pipeline runs; errors shown in plain language with retry timing.
- Light and dark themes; mobile layout in which the disclaimer is never covered.
- Model output is only ever rendered as text. Design details: 05-FRONTEND-DESIGN.

15. Integrations and dependencies

Dependency	Use	Risk
Supabase (Postgres + pgvector, Auth)	Data, vectors, identity	Single region; mitigated by backups (to configure)
EURI (OpenAI-compatible)	Primary chat + embeddings	Quota; mitigated by fallback chain and caching
Google Gemini, Groq	Fallback chat	Not yet verified live
Tavily	Research web search	Not yet verified live
Redis	Cache, short-term memory, rate limits	Optional locally; in-process fallback
AWS (EKS, ECR, ALB, KMS)	Production hosting	Not provisioned (approval required)

16. Release plan

Phase	Scope	Exit criteria	Status
Alpha (local)	Full pipeline, synthetic data, UI, docs	Offline tests + safety suite green; core path verified live	**Achieved**
Beta (controlled)	Docker stack, CI green, live evaluation, clinician review of samples, live research/fallback verified	Live safety suite 100%; no "unsafe" verdicts; Docker smoke test green	Planned
Production v1	AWS deployment, licensed sources, DPAs, region numbers, clinical safety case	Approvals in section 20; SLO monitoring live; penetration test	Planned
v1.x	PDF reports, multilingual, more sources	Per-feature acceptance criteria	Later

17. Risks and mitigations

#	Risk	Likelihood	Impact	Mitigation
R1	Missed emergency	Low	Critical	Rules + LLM, either fires; outage-proof notice; release gate; clinician-reviewed rules
R2	Hallucinated medical fact	Medium	High	Citation/number/drug checks; judge on high-risk; refusal on failure
R3	Dose or diagnosis given	Low	Critical	Scope class + output detectors + verbatim-quote rule; adversarial tests
R4	PHI leakage to third parties	Low	High	Local redaction before egress; probes; DPAs before real data
R5	Prompt injection via uploads/web	Medium	High	Document/web guardrails; untrusted labelling; checks on every answer
R6	Over-refusal reduces usefulness	Medium	Medium	Monitor refusal rate; improve prompts; clinician review
R7	Provider quota/outage	Medium	Medium	Fallback chain, circuit breakers, caching, rate limits
R8	Outdated guidance	Medium	High	Version preference, staleness flags, admin curation
R9	Pattern redaction misses unusual PHI	Medium	High	Minimisation, user guidance, DPAs, future NER model
R10	Regulatory misclassification	Low	High	Information-only intended use; no diagnostic features; legal review

18. Assumptions, constraints and open questions

Assumptions: users have internet access and a modern browser; Supabase remains the data platform; OpenAI-compatible providers stay available.

Constraints: synthetic data only until approvals; free-tier quotas during development; region ap-southeast-2 alongside the database.

Open questions

1. Deployment region and emergency/crisis/poison numbers to configure.
2. Which licensed real sources to ingest first (WHO, NICE, MedlinePlus candidates).
3. Who is the named Clinical Safety Officer?
4. Do any provider agreements permit PHI? Which regions?
5. Is PDF export of evidence reports required for v1?

---

19. Glossary

Term	Meaning
RAG	Retrieval-augmented generation: answering from retrieved documents
Grounding	Every statement supported by a provided passage
Triage	Detection of urgent symptoms requiring emergency advice
ReAct	Reason-and-act agent pattern: the model chooses tools in a loop
RRF	Reciprocal rank fusion of multiple ranked result lists
PHI / PII	Personal health / identifiable information
Faithfulness judge	Temperature-0 model check that every claim is supported by the passages
Golden set	Reference questions with verified evidence for evaluation

20. End-to-end solution overview

How every part of the product fits together, from a user's browser to production operations.

Stage	What happens	Owner component	Design reference
1. Access	User opens the web app; static UI served by nginx with a strict CSP	Frontend	05
2. Identity	Email/password sign-in with Supabase Auth; JWT verified via JWKS; role from `app_metadata`	Auth	04 §4.7
3. Input safety	Question length check, injection/jailbreak block, local PHI and secret redaction	Guardrails	09
4. Triage	Red-flag rules + LLM second opinion; emergency notice built in code	Triage agent	04 §4.1
5. Intent	Scope classification decides the response path	Scope agent	03
6. Evidence	Hybrid retrieval (pgvector + BM25), fusion, re-ranking, version preference; or ReAct research agent	Retriever / research agent	04 §4.2
7. Answer	Grounded generation from numbered passages	Answer agent	ADR-003
8. Verification	Output guardrails, citation/number/drug/dose/diagnosis checks, faithfulness judge	Verifier	04 §4.1
9. Delivery	Streamed phases (SSE), answer card with sources and limitations	API + Frontend	07
10. Memory & report	Redacted, encrypted history; evidence report download	Memory / Report	08
11. Knowledge management	Admin ingestion with provenance; private user uploads; OCR; incremental upsert	Ingestion	04 §4.3
12. Quality	Offline tests, safety suite (release gate), golden-set evaluation in MLflow, clinician review	Evaluation	10
13. Operations	Metrics, dashboards, alerts, audit log, health/readiness probes	Observability	03
14. Delivery pipeline	CI (lint, tests, safety, images, smoke, Trivy) -> CD (OIDC -> ECR -> EKS)	DevOps	12

21. Operational and support requirements

Area	Requirement	Status
Health	Liveness (`/healthz`) never checks dependencies; readiness (`/readyz`) checks the database	Implemented
Monitoring	Dashboards for latency percentiles, safety signals, circuits, cache, rate limits	Implemented as config
Alerting	Triage spike, refusal-rate shift, safety-check failures, open circuits, all models down, p95 latency, 5xx rate	Implemented as config
Incident response	Severity 1 = any "unsafe" clinical verdict, missed-emergency report or PHI exposure: disable affected path, notify Clinical Safety Officer and DPO, root-cause, add regression test before re-enabling	Planned (process)
Audit	One line per request and per action (who, what, outcome), no question/answer text, retained per policy	Implemented
Backups	Database point-in-time recovery enabled and restore tested quarterly	Planned
Data subject requests	Users delete their own history and uploads in-product; DPO handles other requests	Implemented (self-service)
Change management	Every change passes CI; safety-related changes need a safety review (`.claude/agents/safety-reviewer.md`)	Implemented (process + tooling)
Support	In-app guidance for errors (rate limit retry time, "not covered", sign-in issues)	Implemented

22. Requirements traceability matrix

Requirement	Design	Code	Verification (tests)
FR-01, FR-02 Triage + emergency notice	LLD 4.1, ADR-005	`safety/triage.py`, `red_flags.yaml`, `safety/templates.py`	`tests/safety/test_emergency_triage.py`, `test_chat_end_to_end.py`, safety suite
FR-03 Scope	Architecture	`safety/scope.py`	`tests/safety/test_scope_and_refusals.py`
FR-04, FR-07 Grounded generation / not covered	LLD 4.1, ADR-003	`rag/prompts.py`, `agents/rag_graph.py`	`test_chat_end_to_end.py`
FR-05, FR-06 Post-answer checks + judge	LLD 4.1	`safety/answer_checks.py`	`tests/safety/test_answer_checks.py`
FR-09, FR-10 Guardrails + PHI	Security doc	`guardrails/engine.py`, `policy.yaml`	`tests/safety/test_guardrails_and_phi.py`
FR-11 to FR-15 Ingestion	LLD 4.3, Data model	`rag/loaders.py`, `ocr.py`, `chunking.py`, `ingest.py`	`tests/test_ingestion.py`, `test_documents_api.py`
FR-16, FR-17 Retrieval	LLD 4.2	`rag/retrieval.py`, `rerank.py`, `versions.py`, `providers.py`	`tests/test_retrieval_quality.py`, `test_evaluation.py`
FR-18 Research agent	ADR-002, ADR-004	`agents/research.py`	`tests/test_resilience_cache_memory.py`
FR-19, FR-20, FR-27 Memory, cache, retention	LLD 4.5	`rag/memory.py`, `rag/cache.py`	`tests/test_resilience_cache_memory.py`
FR-21, FR-22 Fallback, rate limits	ADR-005	`rag/fallback.py`, `core/circuit_breaker.py`, `core/rate_limit.py`	`tests/test_resilience_cache_memory.py`, `test_api.py`
FR-23 Streaming	API spec	`api/routes_ui_support.py`	`tests/test_ui_support.py`
FR-24 Evidence report	API spec	`rag/report.py`	`tests/test_report.py`, `frontend/tests/ui.spec.js`
FR-25 Clinician review	API spec	`rag/review.py`	`tests/test_evaluation.py`
FR-26 Evaluation	Test strategy	`rag/evaluation.py`, `evals/run_eval.py`, `evals/ragas_crosscheck.py`	`tests/test_evaluation.py`; live run `eval_20261015_111546`

Requirement	Design	Code	Verification (tests)
FR-28 Audit	Security doc	`core/audit.py`, `main.py`	`tests/test_observability.py`
FR-29 Agent trace	LLD 4.1.4, API spec	`rag/trace.py`, `rag/service.py`, `rag/schemas.py`, `frontend/src/app.js`	`tests/test_agent_trace.py`, `frontend/tests/ui.spec.js`
FR-30 LLM gateway, routing, tokens	LLD 4.4.1, ADR-006	`rag/gateway.py`, `rag/llm_gateway.yaml`, `rag/cache.py`	`tests/test_gateway.py`, `tests/safety/test_gateway_safety.py`
NFR security/runtime	Security doc, AWS plan	Dockerfiles, `deploy/k8s`, `infra/terraform`	`tests/test_delivery.py`, CI smoke + Trivy
NFR accessibility/UI	Frontend design	`frontend/src`	`frontend/tests/ui.spec.js`, ESLint

23. Launch readiness checklist (production v1)

#	Item	Status
1	Clinician sign-off of red-flag rules and scope templates	Open
2	Licensed real sources ingested with provenance	Open
3	Live safety suite 100% and live golden-set evaluation recorded in MLflow	Open
4	Clinician review of a sample with zero "unsafe" verdicts	Open
5	DPIA completed; provider DPAs in place for any PHI	Open
6	Region-specific emergency, crisis and poison numbers configured	Open
7	Docker images built, CI green, Trivy clean	Open
8	AWS infrastructure applied with approval; backups and restore tested	Open
9	Dashboards and alerts live; on-call and incident process agreed	Open
10	Penetration test and accessibility audit (WCAG 2.1 AA) completed	Open
11	Offline tests, safety suite and browser tests green	**Done** (419 backend, 240 safety, 10 browser)
12	Core path verified live (ingest, retrieval, answers, emergency, sign-in for all roles)	**Done**

24. Approvals

Role	Name	Decision	Date
Product Owner			
Clinical Safety Officer			
Information Security			
Data Protection Officer			
Engineering Lead			